De Contraseñas a Passkeys: Evolución del Inicio de Sesión Seguro y Observabilidad en Aplicaciones Web, Móviles y de Escritorio

Trabajo de Grado — Seguridad en Aplicaciones

Ingeniería de Sistemas

Presentado por:

[Nombre del estudiante]

Docente:

[Nombre del docente]

[Nombre de la Universidad]

Facultad de Ingeniería

March 20, 2026

Abstract

La gestión de identidades digitales y la supervisión del comportamiento de las aplicaciones representan dos de los desafíos más críticos de la ingeniería de software contemporánea. Los esquemas de autenticación fundamentados en contraseñas estáticas han demostrado ser sistémicamente vulnerables frente a ataques de phishing, credential stuffing y toma de control de cuentas (ATO, *Account Takeover*), vectores responsables de pérdidas económicas globales estimadas en 9,5 billones de dólares anuales [1]. Paralelamente, la creciente complejidad de las arquitecturas distribuidas — microservicios, contenedores efímeros y despliegues multinube — invalida los modelos de monitoreo tradicional basados en umbrales estáticos, incapaces de correlacionar eventos de alto nivel con acciones maliciosas a nivel de kernel.

Este trabajo presenta un análisis técnico y arquitectónico de los mecanismos modernos de inicio de sesión seguro y de los paradigmas de observabilidad profunda. Se examina la transición desde contraseñas hasta passkeys bajo los estándares FIDO2/WebAuthn y el marco OAuth 2.0 con PKCE, diferenciando las estrategias de implementación en plataformas web, móviles y de escritorio. Se analiza además la integración de OpenTelemetry y eBPF (*extended Berkeley Packet Filter*) como pilares de observabilidad, contrastándolos con el monitoreo clásico. El trabajo concluye con la evaluación de conformidad de la arquitectura propuesta frente al estándar NIST SP 800-63-4 [4], el OWASP Top 10 [6] y el marco normativo colombiano (Leyes 1273 de 2009 y 1581 de 2012).

Palabras clave: autenticación, passkeys, FIDO2, WebAuthn, OAuth 2.0, PKCE, observabilidad, OpenTelemetry, eBPF, Zero Trust, seguridad de aplicaciones, NIST SP 800-63-4.

Contents

1 Introducción **3**

2 Marco Teórico **3**

2.1 Fundamentos de Seguridad de la Información 3
2.2 Panorama de Amenazas 4
2.3 Evolución de la Autenticación Digital 4
2.3.1 Contraseñas Estáticas (Secreto Compartido) 4
2.3.2 Autenticación Multifactor Básica (MFA) 4
2.3.3 MFA Resistente al Phishing 5
2.3.4 Passkeys y el Estándar FIDO2 / WebAuthn 5
2.4 Arquitectura de Seguridad Moderna: OAuth 2.0, OIDC y JWT 5
2.4.1 JSON Web Tokens (JWT) 5
2.4.2 OAuth 2.0 Authorization Code con PKCE 6
2.5 Niveles de Garantía de Autenticación: NIST SP 800-63-4 6
2.6 Observabilidad Profunda vs. Monitoreo Tradicional 7
2.6.1 El Abismo Semántico 7
2.6.2 Los Cuatro Pilares: Marco MELT 7
2.6.3 OpenTelemetry (OTel) 7
2.6.4 eBPF (*Extended Berkeley Packet Filter*) 8

3 Marco Legal Colombiano **8**

3.1 Ley 1273 de 2009 — Delitos Informáticos 8
3.2 Ley 1581 de 2012 — Protección de Datos Personales 9

4 Propuesta de Arquitectura Integrada **9**

4.1 Implementación por Plataforma 9
4.1.1 Aplicaciones Web 9
4.1.2 Aplicaciones Móviles Nativas (iOS y Android) 10
4.1.3 Aplicaciones de Escritorio Nativas 10
4.2 Pipeline de Observabilidad para Detección Activa de Amenazas 11
4.2.1 OpenTelemetry: Trazabilidad Estructural del Negocio 11
4.2.2 eBPF: Sensores de Seguridad en Tiempo de Ejecución 11
4.2.3 Prevención de ATO mediante Analítica e Inteligencia Artificial . . . 11

5 Evaluación y Conformidad de la Arquitectura **12**

5.1 Mitigación del OWASP Top 10 12
5.2 Alineación con NIST SP 800-63-4 12
5.3 Cumplimiento del Marco Legislativo Colombiano 12

6 Conclusiones **13**

1. Introducción

La transformación digital ha disuelto los perímetros de red tradicionales. La proliferación del cómputo en la nube, los ecosistemas de dispositivos móviles, el modelo BYOD (*Bring Your Own Device*) y las arquitecturas de microservicios han fragmentado la infraestructura hasta el punto en que cada componente — desde un contenedor efímero hasta un dispositivo personal — representa una superficie de ataque individual que debe protegerse de forma independiente [31]. En este entorno hiperconectado, la **identidad del usuario** se ha convertido en la nueva frontera de control.

El inicio de sesión es el mecanismo algorítmico que determina quién interactúa con el sistema, en qué contexto y con qué nivel de privilegios. Sin embargo, el modelo históricamente dominante — la contraseña estática como "secreto compartido" — presenta vulnerabilidades estructurales insalvables. La reutilización masiva de credenciales (más del 50% de los usuarios reutiliza la misma contraseña en al menos cinco cuentas [15]), combinada con el acceso industrializado a bases de datos filtradas en la Dark Web, ha convertido el *credential stuffing* y el ATO en fenómenos de escala industrial.

De forma paralela, la incapacidad del monitoreo tradicional para detectar intrusiones basadas en credenciales legítimas expone una brecha operacional profunda. Cuando un atacante accede con credenciales válidas pero robadas, los indicadores clásicos de salud del sistema (CPU, memoria, tráfico de red) no registran anomalía alguna, lo cual es reconocido por OWASP como "Fallas en el Registro y Monitoreo de Seguridad" (A09:2021) [6].

Este trabajo aborda la intersección de ambas problemáticas, proponiendo una arquitectura de "Seguridad por Diseño" (*Secure by Design*) [8] que integra (a) flujos de autenticación sin contraseña basados en criptografía asimétrica y (b) una malla de observabilidad profunda sustentada en OpenTelemetry y eBPF.

2. Marco Teórico

2.1. Fundamentos de Seguridad de la Información

La seguridad de la información descansa sobre la tríada CIA (*Confidentiality, Integrity, Availability*), a la que los marcos modernos agregan el **No Repudio** como cuarto pilar [38]:

- **Confidencialidad:** Acceso restringido a entidades autorizadas, garantizado mediante cifrado de estado del arte (AES-256 en reposo, TLS 1.3 en tránsito).
- **Integridad:** Inmutabilidad de los datos, respaldada por funciones hash criptográficas (SHA-256 o superior) y firmas digitales.
- **Disponibilidad:** Acceso oportuno a recursos para usuarios legítimos, mitigando amenazas DoS/DDoS.

- **No Repudio:** Garantía criptográfica de que una acción no puede ser negada por quien la originó.

La estrategia de **Defensa en Profundidad** (*Defense in Depth*) asume que ningún control individual es invulnerable, por lo que exige capas superpuestas de protección [38]. La **Arquitectura Zero Trust** [5, 31] materializa este principio con el axioma "*nunca confiar, siempre verificar*": toda solicitud de acceso debe autenticarse y autorizarse dinámicamente, independientemente de la ubicación topológica del solicitante.

2.2. Panorama de Amenazas

El contexto global y regional justifica la urgencia de adoptar controles modernos. A nivel mundial, los costos del cibercrimen superan los 9,5 billones de dólares anuales [1]. En Colombia, el MinTIC reportó más de 36.000 millones de intentos de ciberataque durante 2024 [34], mientras las denuncias por delitos informáticos crecieron un 23% interanual, superando los 77.600 casos [35]. Los vectores más frecuentes continúan siendo el phishing dirigido, el ransomware y la suplantación de identidad digital.

Los ataques de *credential stuffing* ilustran la industrialización del fraude: utilizando botnets e infraestructuras de proxies residenciales, los actores maliciosos automatizan millones de intentos de autenticación con credenciales filtradas. Análisis del tráfico corporativo revelan que en promedio el 19% de todos los intentos de autenticación diarios corresponde a ataques de este tipo, cifra que puede alcanzar el 44% durante picos coordinados [2].

2.3. Evolución de la Autenticación Digital

La industria ha transitado por cuatro etapas evolutivas claramente diferenciadas:

2.3.1. Contraseñas Estáticas (Secreto Compartido)

El modelo tradicional almacena en el servidor un hash de la contraseña del usuario. Su vulnerabilidad estructural radica en que ambos extremos del canal deben conocer (o derivar) el mismo secreto. Una brecha en la base de datos del servidor compromete todas las cuentas, especialmente cuando se usan algoritmos obsoletos (MD5, SHA-1 sin *salting*) [19].

2.3.2. Autenticación Multifactor Básica (MFA)

La MFA clásica combina *algo que el usuario sabe* (contraseña) con *algo que posee* (dispositivo móvil) o *algo que es* (biometría). Los códigos OTP por SMS, sin embargo, son

susceptibles al secuestro del protocolo SS7, la clonación de SIM (*SIM swapping*) y los ataques AiTM[1] [16].

2.3.3. MFA Resistente al Phishing

Los estándares FIDO U2F introdujeron llaves de seguridad hardware cuya respuesta criptográfica está vinculada al *Origin* (nombre de dominio verificado) del sitio. Si el usuario es engañado y navega a una URL falsa, el token se niega a generar una firma válida para ese dominio, abortando el ataque [15, 16].

2.3.4. Passkeys y el Estándar FIDO2 / WebAuthn

Los **passkeys** representan la eliminación total de la contraseña como factor humano. Fundamentados en la especificación WebAuthn del W3C y el protocolo CTAP2 de la FIDO Alliance [3], operan mediante criptografía asimétrica:

1. **Registro:** El dispositivo genera un par de claves asimétricas único para cada dominio. La **clave privada** queda protegida en el enclave seguro del dispositivo (Secure Enclave en iOS/macOS, TPM en Windows); la **clave pública** se almacena en el servidor.
2. **Autenticación:** El servidor emite un *challenge* aleatorio. El dispositivo, previa verificación biométrica local, firma el challenge con la clave privada. El servidor verifica la firma con la clave pública registrada.

La clave privada **jamás abandona el dispositivo** y está bloqueada por biometría (FaceID, TouchID, Windows Hello) o PIN local. Este diseño erradica algorítmicamente el *credential stuffing*: no hay contraseñas almacenadas en los servidores que puedan robarse. Empíricamente, los passkeys logran tasas de éxito en el inicio de sesión superiores al 98%, reducen la fricción hasta en un 80% y ofrecen inmunidad nativa al phishing [3, 18].

2.4. Arquitectura de Seguridad Moderna: OAuth 2.0, OIDC y JWT

En arquitecturas distribuidas, la autenticación se desacopla lógicamente de los servicios de negocio mediante protocolos estándar:

2.4.1. JSON Web Tokens (JWT)

Tras validar las credenciales, el servidor de identidad emite un JWT firmado criptográficamente. El token contiene *claims* sobre la identidad y los permisos del usuario en

[1] AiTM: *Adversary-in-the-Middle*, donde el atacante intercepta en tiempo real la contraseña y el código OTP.

su *payload*. Los microservicios validan matemáticamente la autenticidad del token verificando su firma, sin consultas sincrónicas a la base de datos central, lo que maximiza escalabilidad y rendimiento [15].

2.4.2. OAuth 2.0 Authorization Code con PKCE

Los clientes públicos (SPAs, aplicaciones móviles nativas, apps de escritorio) no pueden almacenar de forma segura un *client_secret*. La extensión **PKCE** (*Proof Key for Code Exchange*) resuelve esta limitación mediante inyección de entropía dinámica [16]:

1. El cliente genera aleatoriamente un `code_verifier` y calcula su hash SHA-256: el `code_challenge`.
2. Envía solo el `code_challenge` al servidor de autorización al iniciar el flujo.
3. Al canjear el código de autorización por el token, el cliente revela el `code_verifier` original.
4. El servidor verifica que `SHA-256(code_verifier) == code_challenge`.

Un atacante que intercepte el código de autorización no conoce el `code_verifier` almacenado en la memoria del proceso legítimo, por lo que el intento de canje fracasará inevitablemente. PKCE es el estándar obligatorio en 2025 para todo tipo de clientes, incluyendo aplicaciones de escritorio [16, 17].

2.5. Niveles de Garantía de Autenticación: NIST SP 800-63-4

El NIST publicó en 2025 la cuarta revisión de sus Directrices de Identidad Digital (SP 800-63-4) [4], estableciendo tres niveles de garantía (AAL, *Authenticator Assurance Levels*):

Table 1: Niveles de Garantía de Autenticación según NIST SP 800-63-4

Nivel	Requisitos	Aplicaciones Típicas
AAL1	Un solo factor. Desaconsejado para datos personales o sensibles en 2025.	Aplicaciones públicas de bajo riesgo.
AAL2	MFA obligatoria. **Passkeys sincronizables autorizados explícitamente.** Resistencia al phishing promovida.	Nueva línea base para aplicaciones corporativas y comerciales.
AAL3	Máxima garantía. **Prohíbe passkeys sincronizables.** Exige claves ligadas al hardware (*device-bound keys*) no exportables (TPM, Secure Enclave).	Infraestructura gubernamental, sistemas financieros críticos.

La distinción clave del AAL3 es que ni siquiera el proveedor del sistema operativo puede exportar la clave privada del usuario; ésta queda sellada en el chip criptográfico del dispositivo físico [4, 17].

2.6. Observabilidad Profunda vs. Monitoreo Tradicional

2.6.1. El Abismo Semántico

El monitoreo tradicional opera sobre métricas de infraestructura predefinidas (CPU, memoria, latencia) y emite alertas cuando se supera un umbral estático. Es inherentemente **reactivo**: detecta "qué componente falló" solo ante problemas conocidos (*known unknowns*). Cuando un atacante usa credenciales válidas pero robadas, los indicadores de salud permanecen normales. OWASP cataloga esta incapacidad como A09:2021 [6].

La **observabilidad** es una propiedad arquitectónica diseñada desde la concepción del sistema: permite inferir su estado interno a partir de la correlación de sus salidas externas. Es proactiva y causal — responde "*por qué falló*" y permite descubrir anomalías desconocidas (*unknown unknowns*) [20–22].

Table 2: Monitoreo Tradicional vs. Observabilidad Profunda

Dimensión	Monitoreo Tradicional	Observabilidad Profunda (OTel + eBPF)
Enfoque operacional	Reactivo. "Qué ocurrió" / "El sistema falló".	Proactivo y causal. "Por qué falló". Análisis de causa raíz.
Alcance	Métricas de infraestructura predefinidas y logs locales aislados.	Trazas distribuidas correlacionadas + captura a nivel de kernel.
Resolución de problemas	Fallos conocidos y recurrentes (*knowns*).	Fallos complejos y vectores de ataque novedosos (*unknown unknowns*).
Aplicación en ciberseguridad	Detección de anomalías volumétricas obvias (DDoS, bloqueos IP).	Análisis comportamental en microsegundos, detección de exfiltración, perfilado de atacantes persistentes.

2.6.2. Los Cuatro Pilares: Marco MELT

La observabilidad en seguridad de aplicaciones se fundamenta en el marco **MELT** (*Metrics, Events, Logs, Traces*) [20]: métricas cuantitativas del sistema, eventos discretos con contexto de negocio, registros cronológicos estructurados y trazas distribuidas que correlacionan la ejecución de una solicitud a través de múltiples servicios.

2.6.3. OpenTelemetry (OTel)

OpenTelemetry [9] es un marco de código abierto respaldado por la CNCF (*Cloud Native Computing Foundation*) que provee APIs, SDKs y agentes para la recolección estandarizada y agnóstica al proveedor (*vendor-neutral*) de datos telemétricos. Su innovación crítica en ciberseguridad reside en la **trazabilidad distribuida**:

Al registrarse una solicitud de inicio de sesión, el API Gateway inyecta automáticamente un **TraceID** único. Este identificador se propaga en las cabeceras de red a través de cada microservicio, base de datos y componente de infraestructura participante, permitiendo reconstruir la historia cronológica y causal de toda la transacción [9, 10]. Si ese mismo TraceID aparece posteriormente asociado a consultas masivas y atípicas a bases de datos sensibles, la plataforma puede elevar automáticamente una alerta de exfiltración.

2.6.4. eBPF (Extended Berkeley Packet Filter)

eBPF [12] es una tecnología revolucionaria integrada de forma nativa en el kernel Linux (y en adopción acelerada en Windows). A diferencia de los agentes tradicionales que operan en el *user space* — induciendo costosos cambios de contexto (*context switches*) —, eBPF permite inyectar y ejecutar programas personalizados directamente en el núcleo del sistema operativo sin recompilar el kernel ni cargar módulos inestables. Antes de su ejecución, estos programas son verificados por una máquina virtual interna que garantiza la seguridad del kernel.

Desde la perspectiva de seguridad, eBPF ofrece tres capacidades estratégicas [13, 14]:

1. **Instrumentación de Cero Código** (*Zero-Code Instrumentation*): Captura llamadas al sistema (syscalls), eventos de red y operaciones de disco con sobrecarga prácticamente nula (hasta 210 veces menos que agentes en user space), sin requerir que los desarrolladores modifiquen el código fuente.
2. **Detección de intrusiones a nivel de kernel:** Intercepta en microsegundos intentos de lanzar shells remotas, modificar archivos críticos del sistema o inyectar backdoors, exportando telemetría al SIEM antes de que la instrucción maliciosa se consuma.
3. **Inspección pre/post-cifrado TLS:** Al operar antes de que los paquetes sean cifrados por TLS o después de que sean descifrados, eBPF garantiza que ninguna carga útil maliciosa pueda ocultarse dentro de canales aparentemente legítimos y cifrados.

3. Marco Legal Colombiano

El diseño de sistemas de autenticación y observabilidad no es exclusivamente un problema de ingeniería; constituye una responsabilidad jurídica.

3.1. Ley 1273 de 2009 — Delitos Informáticos

Esta ley modificó el Código Penal colombiano para tipificar los delitos informáticos, creando el bien jurídico tutelado "de la protección de la información y de los datos" [36]. Los artículos más relevantes para el diseño de sistemas de autenticación son:

- **Art. 269A (Acceso abusivo):** Sanciona el acceso a sistemas informáticos sin autorización o excediendo los límites acordados. Esto exige que la autenticación esté ligada a un sistema robusto de autorización (e.g., RBAC) que impida la escalada de privilegios.
- **Art. 269G (Suplantación de sitios web):** Penaliza la creación de páginas fraudulentas para capturar credenciales. La implementación de passkeys responde directamente a esta amenaza al vincular criptográficamente la autenticación al dominio real del servicio.
- **Art. 269I (Hurto por medios informáticos):** Sanciona suplantar a un usuario ante sistemas de autenticación para cometer fraude.

3.2. Ley 1581 de 2012 — Protección de Datos Personales

Esta ley estatutaria regula el derecho fundamental al *Habeas Data* [37]. Sus principios rectores imponen obligaciones directas sobre los sistemas de autenticación y observabilidad:

- **Principio de finalidad:** Los datos telemétricos recopilados (IPs, identificadores de dispositivo, patrones de comportamiento) deben usarse exclusivamente para los fines de seguridad informados al usuario.
- **Principio de seguridad:** Obliga a implementar medidas técnicas para evitar adulteración, pérdida o acceso no autorizado. En el contexto de inicio de sesión, aplica a huellas biométricas, tokens de sesión y telemetría comportamental.
- **Principio de libertad:** El tratamiento de datos requiere consentimiento previo, expreso e informado del titular.

4. Propuesta de Arquitectura Integrada

La propuesta adopta un modelo de **Seguridad por Diseño** que adapta el flujo de autenticación a las particularidades de cada plataforma, integrando una malla de observabilidad profunda en el backend.

4.1. Implementación por Plataforma

4.1.1. Aplicaciones Web

Las aplicaciones web operan en un entorno inherentemente hostil donde se ejecuta código JavaScript potencialmente no confiable. Las vulnerabilidades predominantes son XSS (*Cross-Site Scripting*) y CSRF (*Cross-Site Request Forgery*) [29]. Las estrategias recomendadas son:

- **WebAuthn para passkeys:** Registrar los dispositivos del usuario (sensores biométricos integrados, llaves FIDO USB) como autenticadores de primera línea.
- **Patrón BFF y cookies HttpOnly:** En lugar de almacenar JWT en `localStorage` (vulnerable a XSS), utilizar el patrón *Backend-for-Frontend* o cookies con atributos `HttpOnly`, `Secure` y `SameSite=Strict` [16].
- **Cabeceras de seguridad HTTP:** TLS 1.3 obligatorio, HSTS (*HTTP Strict Transport Security*) y una política CSP (*Content Security Policy*) restrictiva que controle el origen de scripts ejecutables [30].

4.1.2. Aplicaciones Móviles Nativas (iOS y Android)

Los dispositivos móviles combinan conectividad persistente con exposición física (redes Wi-Fi públicas, posibilidad de robo). El OWASP Mobile Top 10 [7] subraya el almacenamiento inseguro de datos como vulnerabilidad crítica. Las contramedidas son:

- **Almacenamiento respaldado por hardware:** Los *refresh tokens* deben residir exclusivamente en el **Keychain** (iOS/Secure Enclave) o el **Keystore** (Android/-TEE o Titan M), garantizando que no puedan extraerse en texto plano incluso ante un rooting o jailbreak completo [25].
- **Autenticación biométrica como precondición:** FaceID, TouchID o reconocimiento de iris deben requerirse antes de desbloquear criptográficamente los tokens almacenados.
- **Certificate Pinning:** La aplicación rechaza conexiones TLS a menos que el certificado del servidor coincida con un hash embebido en el binario compilado, neutralizando ataques AiTM en redes comprometidas [25, 26].

4.1.3. Aplicaciones de Escritorio Nativas

Las aplicaciones de escritorio son especialmente vulnerables a la ingeniería inversa, la inyección en DLLs y el volcado de memoria (herramientas como Mimikatz) [28]. Las estrategias son:

- **DPAPI / Keychain Access:** En Windows, la Data Protection API (DPAPI) cifra los tokens vinculándolos a la entropía de las credenciales de sesión local del usuario. En macOS, se usa Keychain Access.
- **Credential Guard:** En despliegues corporativos (Windows Server 2025 / Windows 11 Enterprise), esta característica de virtualización aísla los secretos de autenticación en un contenedor de hipervisor, inaccesible incluso para procesos con privilegios SYSTEM [27].
- **OAuth 2.0 + PKCE para Custom URI Schemes:** Las aplicaciones de escritorio que utilizan manejadores de URL personalizados para recibir el código de

redirección deben exigir PKCE para impedir que malware registrado en el mismo sistema secuestre el código de autorización [16].

4.2. Pipeline de Observabilidad para Detección Activa de Amenazas

4.2.1. OpenTelemetry: Trazabilidad Estructural del Negocio

Se instrumentan los microservicios IAM (*Identity and Access Management*) con los SDKs de OTel. El flujo propuesto es:

1. El API Gateway genera un **TraceID** global al recibir cualquier solicitud (web, móvil o escritorio).
2. El TraceID se propaga en cabeceras HTTP/gRPC por cada componente participante (microservicios, bases de datos, colas de mensajes).
3. El equipo SecOps puede rastrear con precisión forense la ruta temporal y causal de cualquier acción post-autenticación.
4. Si el TraceID de una sesión legítima aparece en consultas masivas a datos sensibles, la plataforma eleva automáticamente una alerta de posible exfiltración [9, 10, 23].

4.2.2. eBPF: Sensores de Seguridad en Tiempo de Ejecución

Los sensores eBPF (implementaciones como OBI — *OpenTelemetry eBPF Instrumentation* [11] o Tetragon) se adjuntan a *tracepoints* y *kprobes* específicos del kernel, observando:

- Cada conexión TCP iniciada por los contenedores de autenticación.
- Cada resolución DNS y llamada al sistema (syscall) de los procesos involucrados.
- Intentos de lanzar shells interactivas, modificar archivos críticos del sistema o instalar backdoors.

Esta aproximación garantiza cobertura telemétrica incluso en componentes de código cerrado o infraestructuras *legacy*, sobre las que el equipo de ingeniería no tiene acceso al código fuente [12, 14].

4.2.3. Prevención de ATO mediante Analítica e Inteligencia Artificial

La telemetría unificada de OTel y eBPF alimenta motores de analítica comportamental e IA, habilitando dos capacidades avanzadas [32, 33]:

1. **Detección de Credential Stuffing en Tiempo Real:** El motor detecta que cientos de intentos de inicio de sesión, aunque provienen de IPs globalmente diversas, comparten patrones sutiles en cabeceras HTTP, temporización y rastros de red, revelándolos como botnets coordinadas. El WAF levanta barreras dinámicas automáticamente.

2. **Biometría Comportamental Continua:** Durante la sesión activa (no solo en el inicio de sesión), la IA analiza la dinámica del cursor, la cadencia de escritura y el ángulo de sostenimiento del dispositivo para perfilar al usuario legítimo. Si el comportamiento detectado corresponde a un script automatizado o a un intruso remoto, el sistema revoca inmediatamente los JWT asociados y exige re-autenticación biométrica.

5. Evaluación y Conformidad de la Arquitectura

5.1. Mitigación del OWASP Top 10

La arquitectura propuesta aborda directamente las categorías OWASP más críticas [6,8]:

- **A01:2021 — Broken Access Control:** Mitigado mediante RBAC integrado con el flujo OAuth 2.0/OIDC y políticas JWT granulares.
- **A07:2021 — Identification and Authentication Failures:** Erradicado algorítmicamente con passkeys FIDO2/WebAuthn, que eliminan las contraseñas almacenadas en servidores.
- **A09:2021 — Security Logging and Monitoring Failures:** Resuelto mediante la malla OTel + eBPF, que garantiza cobertura telemétrica sin puntos ciegos, incluso en arquitecturas de contenedores efímeros.

5.2. Alineación con NIST SP 800-63-4

La arquitectura es plenamente compatible con la revisión 2025 del NIST [4]:

- **AAL2:** Passkeys sincronizables (iCloud Keychain, Google Password Manager) satisfacen los requisitos de MFA resistente al phishing para aplicaciones comerciales estándar.
- **AAL3:** Claves ligadas al hardware (TPM, Secure Enclave) satisfacen el requisito de *device-bound keys* no exportables para infraestructura crítica.

5.3. Cumplimiento del Marco Legislativo Colombiano

- **Ley 1273/2009 [36]:** La telemetría capturada por eBPF genera evidencia digital forense (cadena de custodia) admisible ante la Fiscalía General de la Nación y el CAI Virtual de la Policía, facilitando la persecución del acceso abusivo (Art. 269A).
- **Ley 1581/2012 [37]:** La arquitectura FIDO2 elimina el almacenamiento de contraseñas y secretos biométricos en servidores centralizados, reduciendo drásticamente el riesgo de violación del principio de seguridad del Habeas Data. La telemetría de observabilidad se limita a fines de seguridad, en cumplimiento del principio de finalidad.

6. Conclusiones

La ciberseguridad de aplicaciones en 2025 no puede fundamentarse en la premisa de que el perímetro de red protege los sistemas internos. Con la disolución de las fronteras tradicionales, el proceso de inicio de sesión y los controles de autorización se han convertido en el epicentro del control de acceso, principio rector de cualquier implementación de Arquitectura Zero Trust.

El análisis exhaustivo presentado demuestra que la eliminación de la dependencia de contraseñas estáticas es un mandato técnico y regulatorio. Los passkeys, fundamentados en FIDO2/WebAuthn, erradican algorítmicamente el credential stuffing y el phishing al nivel del protocolo, ofrecen tasas de éxito superiores al 98% y son compatibles con los niveles AAL2 y AAL3 del NIST SP 800-63-4. La extensión PKCE en flujos OAuth 2.0 es igualmente obligatoria para todos los clientes públicos, garantizando que la interceptación del código de autorización sea operativamente inútil para un atacante.

Sin embargo, un flujo de autenticación robusto es solo el primer eslabón de la cadena. La integración estructural de OpenTelemetry y eBPF transforma la postura de seguridad de reactiva a proactiva: OTel teje una trazabilidad distribuida que correlaciona la identidad del usuario con cada acción post-autenticación, mientras que eBPF provee visibilidad a nivel de kernel sin alterar el código fuente ni introducir latencia apreciable. Juntos, habilitan la detección de exfiltración, movimiento lateral y ataques persistentes que son completamente invisibles para el monitoreo tradicional.

Finalmente, la arquitectura satisface simultáneamente los requisitos del OWASP Top 10, el NIST SP 800-63-4 y el marco jurídico colombiano (Leyes 1273 de 2009 y 1581 de 2012), demostrando que la seguridad técnica y el cumplimiento normativo no son objetivos contrapuestos sino sinérgicos. La conjunción de gestión de identidades modernas y observabilidad omnipresente no debe entenderse como una tendencia tecnológica aislada, sino como la única estrategia arquitectónica viable para la supervivencia digital en la era hiperconectada.

References

[1] AuthX, "Account Takeover Statistics 2025: Key Trends & Insights," *AuthX Blog*, 2025. [Online]. Available: https://www.authx.com/blog/account-takeover-fraud-statistics-insights/

[2] Verizon, "Additional 2025 DBIR Research on Credential Stuffing," *Verizon Business Resources*, 2025. [Online]. Available: https://www.verizon.com/business/resources/articles/credential-stuffing-attacks-2025-dbir-research/

[3] MojoAuth, "Passkeys Handbook 2025: Secure, Passwordless Authentication," *MojoAuth White Papers*, 2025. [Online]. Available: https://mojoauth.com/white-papers/passkeys-passwordless-authentication-handbook/

[4] NIST, "Digital Identity Guidelines: SP 800-63-4," *NIST Special Publication 800-63-4*, National Institute of Standards and Technology, 2025. [Online]. Available: https://pages.nist.gov/800-63-4/sp800-63.html

[5] NIST NCCoE, "Implementing a Zero Trust Architecture," *NIST National Cybersecurity Center of Excellence*, 2025. [Online]. Available: https://www.nccoe.nist.gov/projects/implementing-zero-trust-architecture

[6] OWASP Foundation, "OWASP Top Ten 2021," *Open Web Application Security Project*, 2021. [Online]. Available: https://owasp.org/www-project-top-ten/

[7] OWASP Foundation, "Mobile Top 10 2024," *Open Web Application Security Project*, 2024. [Online]. Available: https://owasp.org/www-project-mobile-top-10/

[8] OWASP Foundation, "OWASP Secure by Design Framework," *Open Web Application Security Project*, 2024. [Online]. Available: https://owasp.org/www-project-secure-by-design-framework/

[9] OpenTelemetry, "OpenTelemetry: An Observability Framework for Cloud-Native Software," *Cloud Native Computing Foundation*, 2025. [Online]. Available: https://opentelemetry.io/

[10] D. Horovits, "Unveiling OpenTelemetry eBPF Instrumentation," *Medium*, 2025. [Online]. Available: https://horovits.medium.com/unveiling-opentelemetry-ebpf-instrumentation-377cb0432bf1

[11] OpenTelemetry, "OpenTelemetry eBPF Instrumentation Marks the First Release," *OpenTelemetry Blog*, 2025. [Online]. Available: https://opentelemetry.io/blog/2025/obi-announcing-first-release/

[12] Linux Foundation, "eBPF for the Infrastructure Platform: The State of eBPF 2025," *Linux Foundation*, 2025. [Online]. Available: https://www.linuxfoundation.org/hubfs/eBPF/The_State_of_eBPF25_111925.pdf

[13] J. Doe *et al.*, "eBPF-Enhanced Complete Observability Solution for Cloud-Native Microservices," *ResearchGate*, 2024. [Online]. Available: https://www.researchgate.net/publication/379891642

[14] Groundcover, "OpenTelemetry and eBPF: Everything You Need to Know," *Groundcover Blog*, 2025. [Online]. Available: https://www.groundcover.com/ebpf/opentelemetry-ebpf

[15] Frontegg, "What Is User Authentication? A 2025 Guide for Modern Apps," *Frontegg Blog*, 2025. [Online]. Available: https://frontegg.com/blog/authentication

[16] J. R. S. Adari, "Building Secure Authentication Layers: A Complete Guide for 2025," *srivathsav.me*, 2025. [Online]. Available: https://srivathsav.me/blog/building-secure-authentication-layers-2025

[17] HYPR, "NIST SP 800-63-3 & 63-4: Digital Identity Guidelines Review," *HYPR Blog*, 2025. [Online]. Available: https://www.hypr.com/blog/nist-sp-800-63-3-digital-identity-guidelines-review

[18] Authsignal, "Passwordless Authentication in 2025: The Year Passkeys Went Mainstream," *Authsignal Blog*, 2025. [Online]. Available: https://www.authsignal.com/blog/articles/passwordless-authentication-in-2025-the-year-passkeys-went-mainstream

[19] Google Cloud, "Modern Password Security for System Designers," *Google Cloud Documentation*, 2024. [Online]. Available: https://docs.cloud.google.com/solutions/modern-password-security-for-system-designers.pdf

[20] New Relic, "Observability vs. Monitoring: What's the Difference?" *New Relic Blog*, 2025. [Online]. Available: https://newrelic.com/blog/observability/observability-vs-monitoring

[21] CrowdStrike, "Observability vs. Monitoring: What's the Difference?" *CrowdStrike Cybersecurity 101*, 2025. [Online]. Available: https://www.crowdstrike.com/en-us/cybersecurity-101/observability/observability-vs-monitoring/

[22] Dynatrace, "Observability vs. Monitoring: What's the Difference?" *Dynatrace Blog*, 2025. [Online]. Available: https://www.dynatrace.com/news/blog/observability-vs-monitoring/

[23] The New Stack, "Observability in 2025: OpenTelemetry and AI to Fill In Gaps," *The New Stack*, 2025. [Online]. Available: https://thenewstack.io/observability-in-2025-opentelemetry-and-ai-to-fill-in-gaps/

[24] CNCF, "Observability Trends in 2025 – What's Driving Change?" *Cloud Native Computing Foundation Blog*, 2025. [Online]. Available: https://www.cncf.io/blog/2025/03/05/observability-trends-in-2025-whats-driving-change/

[25] T. Al-Turjman *et al.*, "A Review on Secure Authentication Mechanisms for Mobile Security," *MDPI Sensors*, vol. 25, no. 3, p. 700, 2025. DOI: 10.3390/s25030700.

[26] Touchlane, "Common Mobile Application Security Vulnerabilities 2025," *Touchlane Blog*, 2025. [Online]. Available: https://touchlane.com/common-mobile-application-vulnerabilities-2025/

[27] Microsoft, "What's New in Windows Server 2025," *Microsoft Learn*, 2025. [Online]. Available: https://learn.microsoft.com/en-us/windows-server/get-started/whats-new-windows-server-2025

[28] Chudovo, "Why Desktop Applications Will Still Be in Demand in 2025," *Chudovo Blog*, 2025. [Online]. Available: https://chudovo.com/why-desktop-applications-will-still-be-in-demand/

[29] StackHawk, "10 Web Application Security Threats for 2025 & How to Respond," *StackHawk Blog*, 2025. [Online]. Available: https://www.stackhawk.com/blog/10-web-application-security-threats-and-how-to-mitigate-them/

[30] Oligo Security, "Web App Security in 2025: 5 Technologies You Can't Do Without," *Oligo Academy*, 2025. [Online]. Available: https://www.oligo.security/academy/web-app-security-in-2025-5-technologies-you-cant-do-without

[31] Northern Technologies Group, "Zero Trust Architecture in 2025: Shifting from Perimeter Security to 'Never Trust, Always Verify'," *NTG Blog*, 2025. [Online]. Available: https://ntgit.com/zero-trust-architecture-in-2025-shifting-from-perimeter-security-to-never-trust-a

[32] CLEAR, "Fraud Analytics in 2025: Why Traditional Systems Fail," *CLEAR Identity Blog*, 2025. [Online]. Available: https://identity.clearme.com/post/fraud-analytics-2025-why-traditional-systems-fail

[33] DigitalOcean, "Understanding AI Fraud Detection and Prevention in 2026," *DigitalOcean Resources*, 2025. [Online]. Available: https://www.digitalocean.com/resources/articles/ai-fraud-detection

[34] ACIS, "Colombia enfrenta récord de 36.000 millones de ciberataques en 2024," *Asociación Colombiana de Ingenieros de Sistemas*, 2024. [Online]. Available: https://www.acis.org.co/blog/noticias-2/colombia-enfrenta-record-de-36000-millones-de-ciberataques-en-2024-4964

[35] CCIT, "Balance de Ciberseguridad 2024: Desafíos y prevención para un entorno digital seguro," *Cámara Colombiana de Informática y Telecomunicaciones*, 2024. [Online]. Available: https://www.ccit.org.co/noticias/balance-de-ciberseguridad-2024-desafios-y-prevencion-para-un-entorno-digital-segu

[36] Congreso de la República de Colombia, "Ley 1273 de 2009: Por medio de la cual se modifica el Código Penal, se crea un nuevo bien jurídico tutelado denominado 'de la protección de la información y de los datos'," 2009. [Online]. Available: https://www.armada.mil.co/sites/default/files/normograma_arc/telematica/Ley%201273%20de%202009%20Modifica%20CP%20para%20protecci%C3%B3n%20de%20datos%20e%20informaci%C3%B3n.pdf

[37] Congreso de la República de Colombia, "Ley 1581 de 2012: Por la cual se dictan disposiciones generales para la protección de datos personales," 2012. [Online]. Available: https://www.alcaldiabogota.gov.co/sisjur/normas/Norma1.jsp?i=49981

[38] International Organization for Standardization, "ISO/IEC 27001:2022 – Information Security Management Systems," *ISO*, 2022.

[39] Authsignal, "How to Actually Stop Credential Stuffing in 2025," *Authsignal Blog*, 2025. [Online]. Available: https://www.authsignal.com/blog/articles/how-to-actually-stop-credential-stuffing-in-2025